Bounty Hacker: Write Up

Plataforma: TryHackMe

Máquina / Desafio:	Bounty Hacker
Dificuldade:	Fácil
Data de Resolução:	1 de outubro de 2026
Autor:	Alan Dias (alankk)

1 de outubro de 2026

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **3**

4 Escalada de Privilégios **5**

5 Conclusão **6**

6 Referências **6**

1 Visão Geral

A máquina *Bounty Hacker* é um desafio focado na exploração de serviços de rede comuns mal configurados e em falhas na gestão de permissões. A superfície de ataque inicial concentra-se em um serviço de transferência de arquivos que expõe dados sensíveis de desenvolvimento. O caminho geral para o comprometimento da máquina envolve a coleta desses artefatos para a realização de ataques de dicionário, garantindo o acesso remoto inicial, seguido do abuso de privilégios delegados incorretamente a um utilitário básico do sistema para obter controle total do ambiente.

2 Reconhecimento

A fase inicial consistiu em um escaneamento completo de portas utilizando a ferramenta `nmap`. O objetivo foi revelar todos os serviços expostos pela máquina alvo.

```
nmap -A -T4 <TARGET_IP>
```

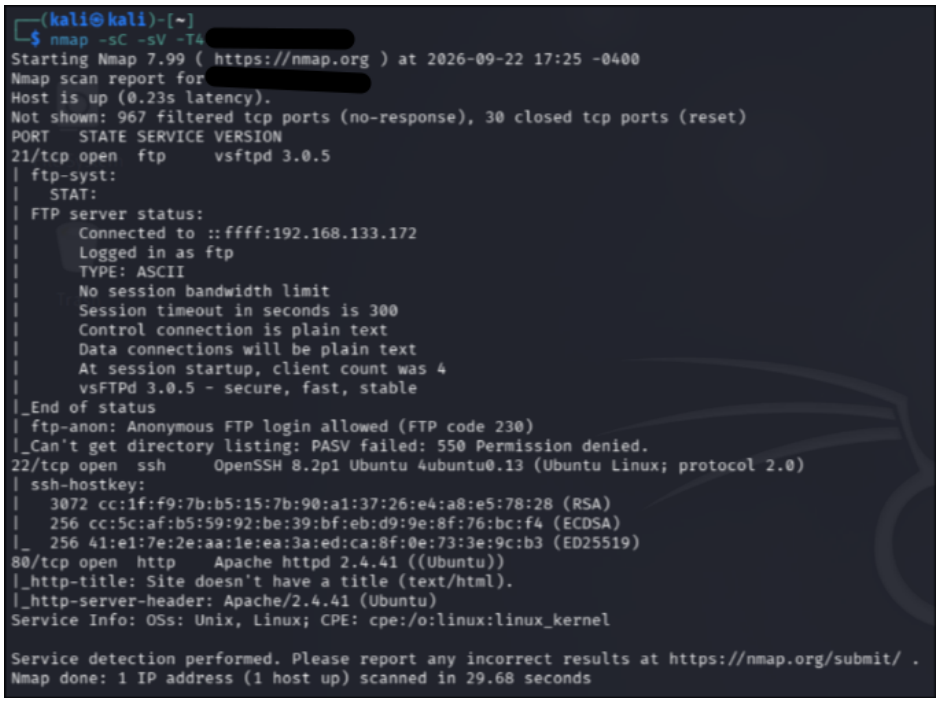


Figura 1: Varredura de portas com Nmap revelando os serviços FTP, SSH e HTTP.

O escaneamento revelou os seguintes serviços relevantes:

- **Porta 21 (FTP):** Com o recurso vital de *Anonymous FTP login allowed* (acesso anônimo habilitado).
- **Porta 22 (SSH):** Canal potencial para acesso direto caso credenciais fossem comprometidas.
- **Porta 80 (HTTP):** Um serviço web que, a priori, não indicava vetores de entrada críticos para esta rota específica do ataque.

3 Exploração

Diante do acesso anônimo garantido no servidor FTP (porta 21), a primeira ação foi conectar-se ao serviço para enumerar arquivos disponíveis publicamente.

```
ftp <TARGET_IP>
```

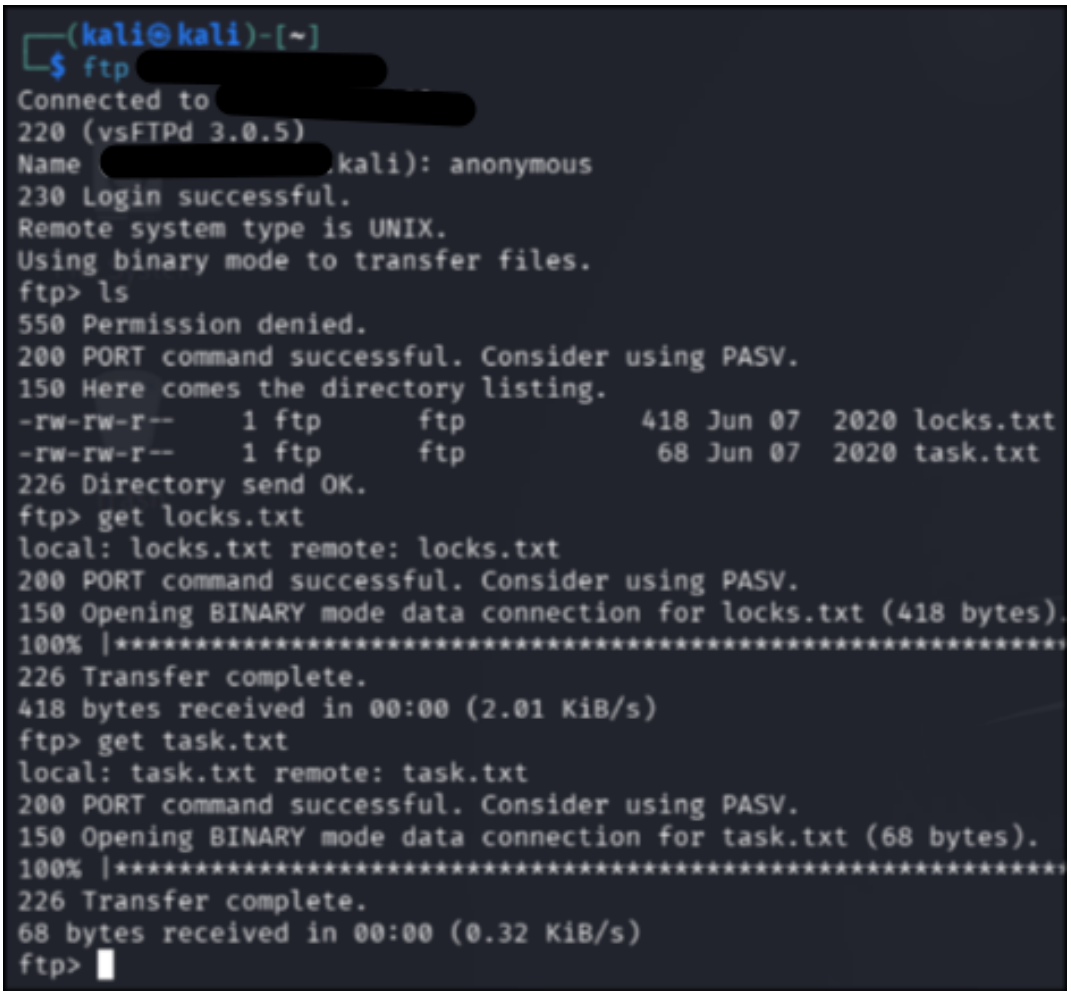


Figura 2: Conexão FTP como ”anonymous”e listagem de diretórios.

A listagem dentro do FTP revelou dois arquivos cruciais: `tasks.txt` e `locks.txt`. Baixando e analisando ambos localmente, constatou-se que o arquivo `tasks.txt` apresentava assinaturas sob o nome ”lin”— o que o elevava a um potencial nome de usuário para o serviço SSH. Além disso, o arquivo `locks.txt` assemelhava-se a uma lista de palavras customizada, típica de um pequeno banco de senhas (*wordlist*).

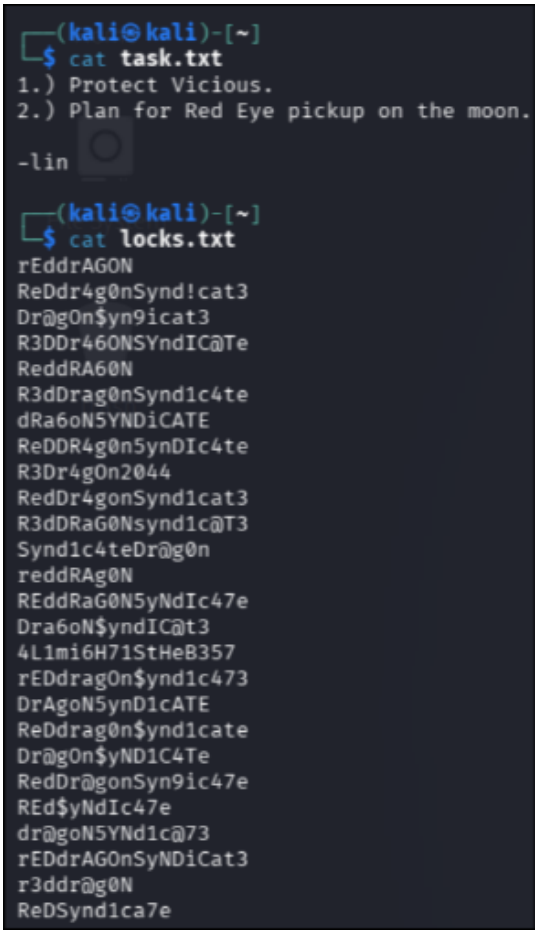


Figura 3: Leitura dos arquivos contendo o possível nome de usuário e dicionário de senhas.

Munidos de um nome de usuário válido (`lin`) e de um dicionário de possíveis senhas (`locks.txt`), o foco voltou-se para a porta 22 (SSH). Utilizou-se a ferramenta `hydra` para executar um ataque de força bruta (*brute-force*) otimizado contra o serviço.

```
hydra -l lin -P locks.txt ssh://<TARGET_IP>
```

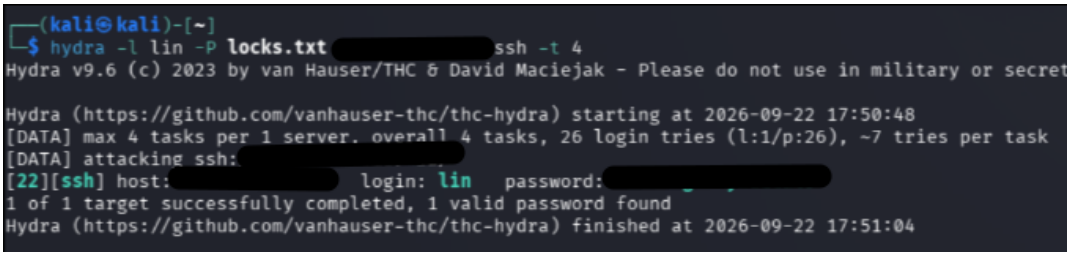


Figura 4: Ataque de força bruta utilizando o Hydra para descobrir a credencial correta.

O `hydra` concluiu a varredura com sucesso, quebrando a senha (`<PASSWORD>`). Utilizando essas credenciais, foi possível acessar o servidor via SSH, obtendo a *shell* inicial de usuário baixo e capturando a primeira *flag*.

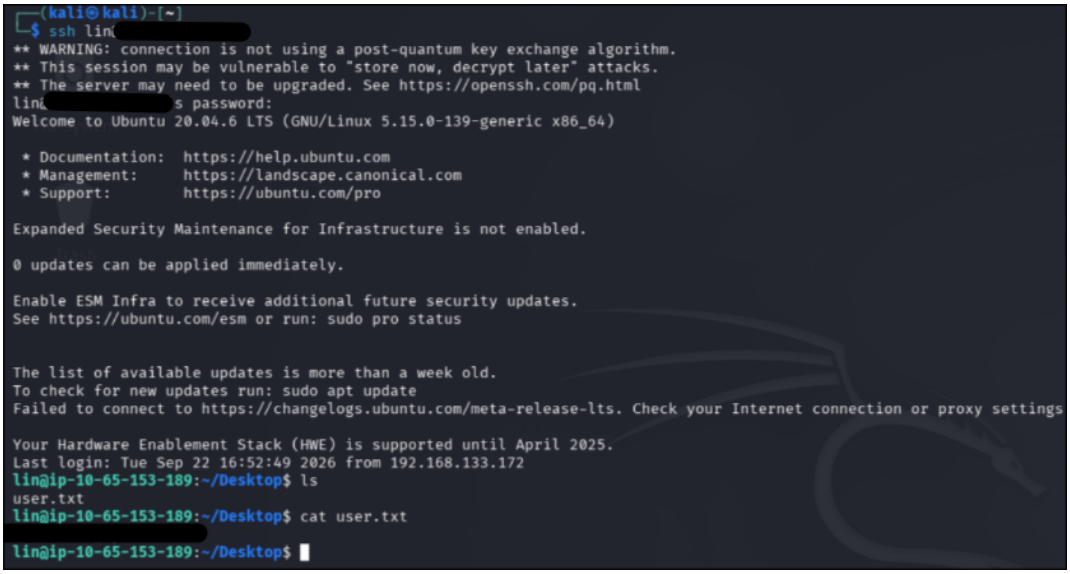


Figura 5: Login SSH bem-sucedido com o usuário lin e obtenção da primeira flag.

4 Escalada de Privilégios

O objetivo final da invasão era comprometer completamente a máquina, o que requer credenciais de superusuário (`root`). Para elencar possíveis vetores, iniciou-se a enumeração de permissões locais verificando se o usuário `lin` possuía direitos de execução de comandos como `root` via `sudo`.

```
sudo -l
```

A saída do comando revelou que o usuário estava autorizado a executar o binário `/bin/tar` com privilégios máximos e sem a exigência de fornecimento de senha. Sabe-se que o `tar` apresenta métodos para execução arbitrária de comandos em sistemas Unix através de sua funcionalidade de *checkpoints*.

Utilizando as referências do repositório *GTFOBins*, injetou-se um comando estruturado para que o `tar` invocasse uma nova *shell* durante o empacotamento, resultando em uma *shell* interativa de root.

```
sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/
    bin/sh
```

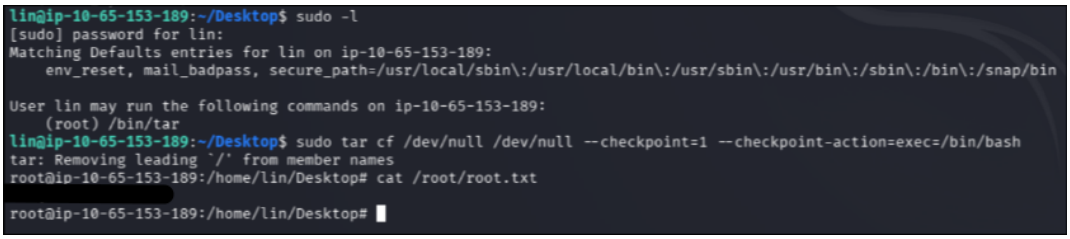


Figura 6: Escalada de privilégios via binário tar e leitura da flag de root.

O comando rendeu acesso absoluto (`root`), o que permitiu a coleta do último artefato do desafio, finalizando o *pentest*.

5 Conclusão

O laboratório *Bounty Hacker* sublinha o perigo iminente de configurações padrão desleixadas. A ativação do acesso anônimo no FTP expôs artefatos sensíveis do sistema de desenvolvimento que, uma vez combinados a políticas fracas de senhas, permitiram que um *brute-force* rudimentar comprometesse o SSH. Por conseguinte, a má administração das regras do `sudoers` ofereceu a execução de comandos irrestritos usando o `tar`, subvertendo as defesas do sistema operacional e demonstrando os ricos resultados do encadeamento de falhas (*exploit chaining*).

6 Referências

- **Hydra - Kali Linux Tools:**
  https://www.kali.org/tools/hydra/
- **GTFOBins - Tar:**
  https://gtfobins.org/gtfobins/tar/